침해평가 인사이트

나루씨큐리티 위협대응센터 동료들과 함께.

기업의 정보보안 리더들은 무엇을 이상하게 생각하는가?

"4년간 방치된 SKT 해킹"

SK텔레콤(SKT)이 4년 전인 2021년 8월부터 해킹 공격을 받았고, 2022년 해킹 흔적을 발견할 기회가 있었음에도 신고 없이 자체 조치로 사고를 막을 기회를 [illegible] 식별 모듈) 해킹 사고의 귀책이 SKT에 있다고 보고, SKT가 이용자들의 계약 해지 위약금을 면제해 줘야 한다는 판단을 내놨다.

"KT 서버 43대 1년 전 뚫렸다"

KT는 올해 SK텔레콤 해킹 사고 후 외부 보안 전문 기업에 의뢰해 전사 서버를 대상으로 4개월에 걸쳐 조사를 진행했고, 그 결과 해킹 정황이 확인됐습니다.

구체적으로는 서버 침해 흔적 4건, 의심 정황 2건입니다.

"정부 업무망 3년간 뚫렸었다"

아직 정체가 밝혀지지 않은 해커 조직이 정부원격근무시스템(G-VPN)에 로그인할 수 있는 인증서와 비밀번호 등을 훔쳐 최근 3년간 정부 내부 업무관리 전산망인 '온나라시스템'에 접속해 자료를 열람한 사실이 확인됐다. 뿐만 아니라 정부 부처가 자체 운영하는 일부 시스템에도 접속했다. 해킹 커뮤니티에서 최고 권위를 인정받는 웹진인 '프랙

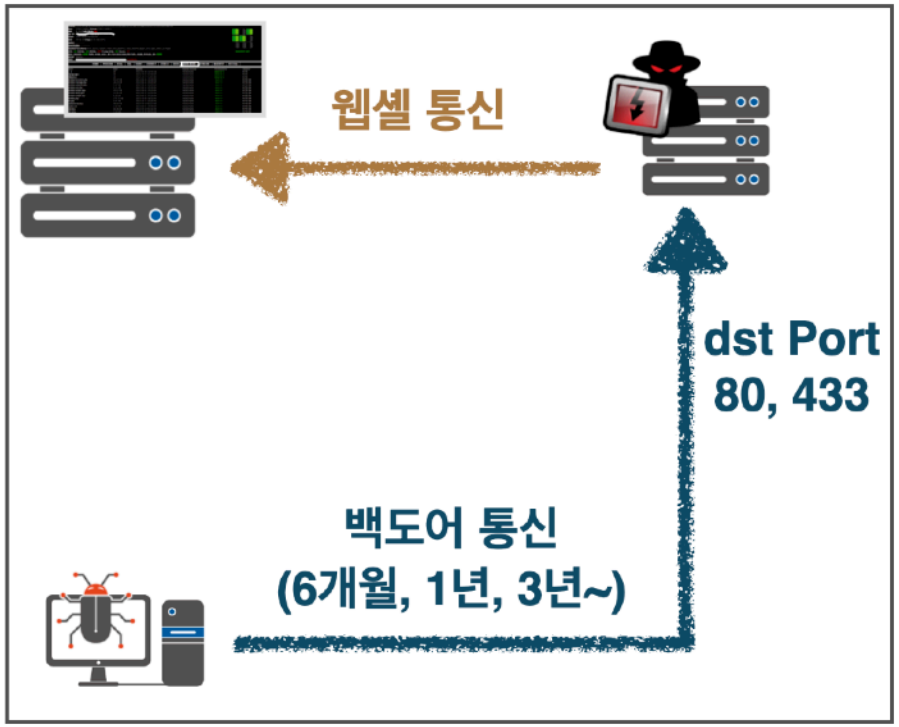
"8개월간 지속적으로 개인정보 탈취"

이어 "운영 중인 모든 인터넷 사이트로 범위를 확대해 최근 1년간의 로그(기록)를 추가 분석한 결과, 홈쇼핑 웹사이트에서도 2024년 6월 21일부터 2025년 2월 13일 사이 동일 수법으로 약 158만 건의 개인정보 유출 정황을 확인했다"고 말했다.

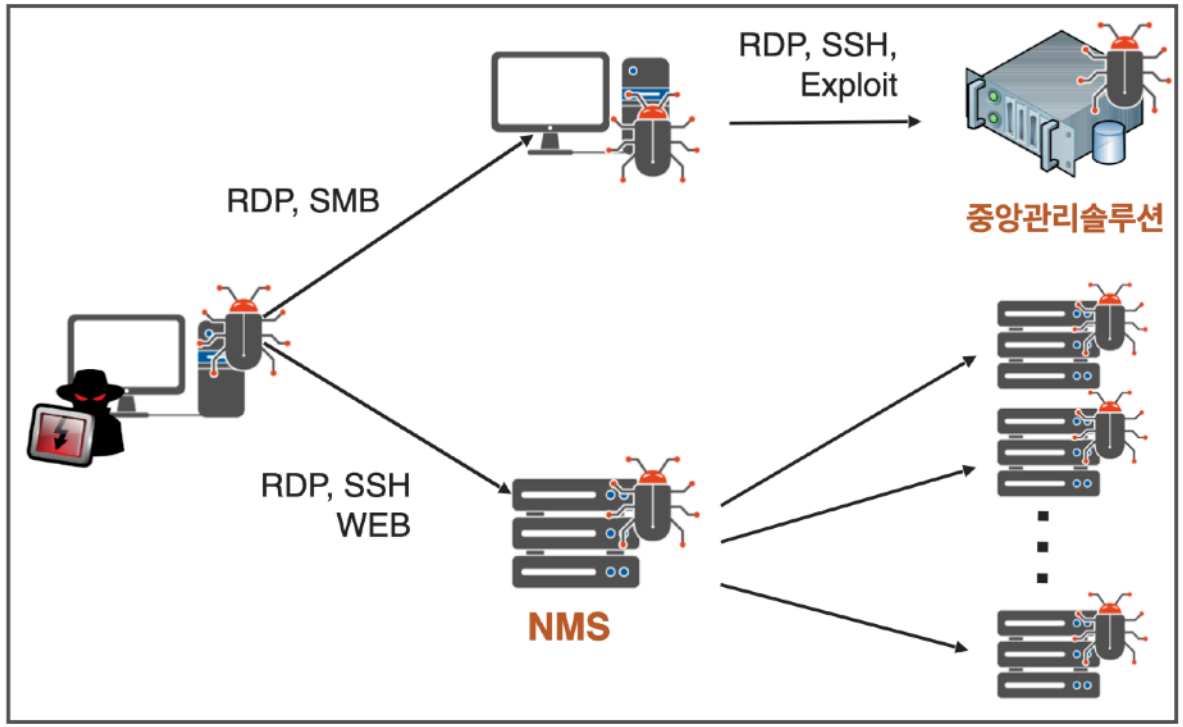
침투 기법이 아닌 드웰타임(Dwell Time)에 대한 궁금증

사이버보안 서비스 또는 전문가들에게 어떤 질문을 던지고 있는가?

1st 아웃바운드 은닉 채널 & 인바운드 웹셸 탐지 체계의 헛점



2nd 측면이동과 거점구축 행위 모니터링 체계 부재



정보보안 체계 사각지대에 대한 깊은 공감

NARUSECURITY

기존 보안 패러다임이 급변하는 사이버 환경에서 효능감을 유지할 수 있는가?

| 기존 보안 서비스의 질문

뚫릴 가능성이 있는가?

| 침해 평가 서비스의 질문

이미 뚫려있는 것은 아닌가?

중소기업

30%

대기업

70%

고객이 실질적으로 효능감을 느끼는 부분은 무엇인가?

악성이 발견된 고객사 ’25%’

운영맥락 이해

자산 & 역할

가시성 확보

측면이동 공간

정상성 회복

불필요한 노이즈 통신

그리고, 이 모든 효능감을 극대화시키는 것은?

소통(=내재화)

(서비스 내용을 기반으로 고객과 지속적으로 인식 수준을 맞추는 과정)

가시성을 저해하는 통신은 왜 제거해야 하는가?

중앙관리솔루션의 웹로그는 왜 분석해야 하는가?

& 타사에서는 어떠한 침투 행위가 탐지되고 있는가?

침해 여부를 검증하기 위한 체계적 접근 방법론

1단계 아웃바운드 통신 평가

내부망에 아웃바운드 백도어 채널이 존재하는지 여부 확인

2단계 인바운드 통신 평가

인바운드 공격행위(웹셸, 크리덴셜스터핑) 존재여부 확인

3단계 측면이동 통신 평가

측면이동 공격과 관련된 행위 존재여부 확인

4단계 중앙관리형 자산 통신 평가

인터넷 연결성 높은 자산에 공격행위가 존재하는지 여부 확인

5단계 목적지 IP 평판 평가

나루씨큐리티 위협 인텔리전스 정보와 맵핑하여 위협여부 확인

6단계 보안통제 우회 통신 평가

보안 체계를 우회하는 통신 존재여부 확인

7단계 대용량 데이터 이동통신 평가

인터넷 구간으로 나가는 아웃바운드 통신 중 대용량 데이터 이동 확인

8단계 망에서 발생되는 통신의 변화 평가

각 구간별 발생되는 통신 플로우 및 프로토별 변화 확인

기술이 아닌 효능감을 제공하는 보안

정보보안 담당자가

“나는 이 상황을 통제할 수 있다고 느낄 수 있도록 만드는 것”